

Bug & Security Assessment Report

System Under Test: index.html · Exploratory Testing

Overview

This report documents 14 findings identified during manual exploratory testing. Issues range from critical authentication flaws and session vulnerabilities to game-logic bugs, input validation gaps, and localization defects. Each finding includes reproduction steps, expected vs. actual behavior, and severity classification aligned with OWASP where applicable.

Finding Summary

ID	Title	Severity	Module
BUG-01	No Password Required for Login	Critical	Authentication / Security
BUG-02	Hint Always Suggests the Same Cell (Easy Mode)	Critical	Game Logic / Hint System
BUG-03	Emoji-Only Usernames Accepted	Critical	Authentication / Input Validation
BUG-04	Session Stays Active After Account Deletion	Critical	Session Management
BUG-05	Session Token Is the Username	High	Session Management / Security
BUG-06	Opening Game URL in New Tab Starts a New Game	High	Session / Multi-tab Behavior
BUG-07	Game Progress Lost on Page Refresh	High	State Management
BUG-08	No Input Length Limit — UI Break and Storage Risk	High	Input Validation / Security
BUG-09	Difficulty Setting Has No Effect on Gameplay	High	Game Logic
BUG-10	All User Data Stored as Plain Text	High	Data Storage / Security
BUG-11	Farsi Characters Accepted in English Mode	Medium	Input Validation
BUG-12	Profile Timestamps Tied to Local System Clock	Medium	Profile / Time Handling
BUG-13	Incomplete Farsi Translation on Profile Page	Medium	Localization
BUG-14	JavaScript Source Code Is Obfuscated	Info	Security / Code Transparency

Critical Findings

BUG-01 No Password Required for Login **CRITICAL** · OWASP A07:2021

Module: Authentication / Security

Description The app authenticates users by username only. Anyone who knows a valid username can access that account instantly.

Steps to Reproduce

1. Register a new account (e.g. "Alice")
2. Log out
3. Type "Alice" on the login screen
4. Submit

Expected A password or second factor is required before access is granted.

Actual The user is logged in immediately with no credential check.

BUG-02 Hint Always Suggests the Same Cell (Easy Mode) **CRITICAL**

Module: Game Logic / Hint System

Description In Easy mode, the Hint button always highlights the same cell (top-right, row 1) regardless of board state or occupancy.

Steps to Reproduce

5. Start a new game in Easy mode
6. Click Hint — note the suggested cell
7. Make moves; let the opponent occupy that cell
8. Click Hint again

Expected Hint should analyze the current board and suggest a valid, strategic move.

Actual The same fixed cell is always highlighted, even when it is already occupied.

BUG-03 Emoji-Only Usernames Accepted **CRITICAL**

Module: Authentication / Input Validation

Description The app accepts emoji-only strings as valid usernames, bypassing any meaningful identity validation.

Steps to Reproduce

9. Open the registration screen
10. Enter an emoji-only username (e.g. 😊👤🎮)
11. Submit the form

Expected Usernames should follow alphanumeric validation rules and reject emoji-only input.

Actual Emoji usernames are accepted and used for authentication without any error.

BUG-04 Session Stays Active After Account Deletion **CRITICAL****Module:** Session Management

Description	Deleting an account in one tab does not invalidate the session in other open tabs.
Steps to Reproduce	12. Open the game in Tab A and Tab B 13. Delete the account from Tab A 14. Return to Tab B and continue playing
Expected	All sessions should be invalidated immediately upon account deletion.
Actual	The user remains fully authenticated and can continue playing in Tab B.

 High Findings**BUG-05 Session Token Is the Username** **HIGH** · OWASP A01:2021**Module:** Session Management / Security

Description	localStorage stores the raw username as the session token. Any attacker can impersonate a user by setting this value manually.
Steps to Reproduce	15. Log in with any account 16. Open DevTools → Application → Local Storage 17. Change the session value to another existing username 18. Refresh the page
Expected	Session tokens should be cryptographically random and not guessable.
Actual	The app accepts the manually set username as a valid session and logs in.

BUG-06 Opening Game URL in New Tab Starts a New Game **HIGH****Module:** Session / Multi-tab Behavior

Description	Pasting the current game URL into a new tab creates a fresh session instead of continuing the active game.
Steps to Reproduce	19. Start a game in Tab A and make a few moves 20. Copy the URL 21. Open it in Tab B
Expected	The existing game state should be restored or the user informed of the conflict.
Actual	A brand-new empty game board appears; all previous progress is invisible.

BUG-07 Game Progress Lost on Page Refresh HIGH**Module:** State Management

Description	Refreshing the page destroys the current game with no warning and no recovery option.
Steps to Reproduce	22. Start a game and make several moves 23. Press F5 or the browser refresh button
Expected	Game state should persist (e.g. via localStorage) or a confirmation prompt shown.
Actual	The game resets completely and all progress is lost.

BUG-08 No Input Length Limit — UI Break and Storage Risk HIGH · OWASP A04:2021**Module:** Input Validation / Security

Description	The name field accepts unlimited characters, breaking the layout and potentially exhausting localStorage.
Steps to Reproduce	24. Go to the registration screen 25. Paste 10,000+ characters into the name field 26. Submit the form
Expected	Input should be capped (e.g. 30 characters) with a clear validation message.
Actual	The long string is saved, the UI overflows, and localStorage can be filled up.

BUG-09 Difficulty Setting Has No Effect on Gameplay HIGH**Module:** Game Logic

Description	Switching from Easy to Hard mode produces no observable change in the computer's gameplay or challenge level.
Steps to Reproduce	27. Start a game on Easy mode and play until completion 28. Switch difficulty to Hard mode 29. Start a new game and play until completion 30. Compare the computer's move quality and challenge level between both modes
Expected	Hard mode should present a noticeably greater challenge, with the computer making stronger, more strategic moves.
Actual	The computer plays identically on both settings; Hard mode is indistinguishable from Easy in practice.

BUG-10 All User Data Stored as Plain Text HIGH · OWASP A02:2021

Module: Data Storage / Security

Description	User data (username, game history, metadata) is saved as unencrypted plain JSON in localStorage.
Steps to Reproduce	31. Register and log in 32. Open DevTools → Application → Local Storage 33. Inspect the users key
Expected	Sensitive data should not be stored in readable plain text on the client side.
Actual	All user records are fully visible as plain JSON with no encryption.

 Medium Findings**BUG-11 Farsi Characters Accepted in English Mode** MEDIUM

Module: Input Validation

Description	The display name field accepts Farsi text even when the app language is set to English.
Steps to Reproduce	34. Set application language to English 35. Enter Farsi text in the display name field 36. Submit
Expected	Input validation should reject characters outside the active language character set.
Actual	Farsi text is accepted and saved without any validation error.

BUG-12 Profile Timestamps Tied to Local System Clock MEDIUM

Module: Profile / Time Handling

Description	Displayed creation dates change when the OS clock is modified, since the app relies entirely on client-side time.
Steps to Reproduce	37. Note the creation date shown on the profile page 38. Change the operating system date/time 39. Reopen the app and check the profile
Expected	Timestamps should reflect the actual registration time and not be manipulable by the user.
Actual	The displayed date changes to match the modified system clock.

BUG-13 Incomplete Farsi Translation on Profile Page MEDIUM

Module: Localization

Description	When Farsi is selected, some UI labels on the Profile page remain in English (e.g. "Created").
Steps to Reproduce	40. Switch the app language to Farsi 41. Navigate to the Profile tab 42. Review all visible labels
Expected	Every UI text element should be translated when Farsi is active.
Actual	Labels such as "Created" stay in English; the rest of the page is translated.

Informational

BUG-14 JavaScript Source Code Is Obfuscated INFO · OWASP A08:2021

Module: Security / Code Transparency

Description	The entire JS bundle is heavily obfuscated, making security audits and maintenance significantly harder.
Steps to Reproduce	43. Open the app in a browser 44. View Page Source or open DevTools → Sources
Expected	Code should be readable and auditable (or minified without deliberate obfuscation).
Actual	The source is obfuscated with encoded string arrays and anti-analysis patterns. Not a direct vulnerability but flags a transparency risk.

Conclusion

14 findings were identified across authentication, game logic, session management, input validation, and localization. The most critical risks center on the lack of password-based authentication and weak session token design. These should be addressed before any production deployment.

4 Critical · 6 High · 3 Medium · 1 Informational